

DET-002 | Password Spraying Detection HIGH

ID: DET-002

MITRE ID: T1110.003

Data Source: SigninLogs

Severity • HIGH

Tactic: Credential Access

Category IDENTITY

ADX MAPPING LOGIC:

Mapping: Source = 'Attacker IP', State = 'targeted account/user', EventType = 'failure reason'.

Spray = one Source hitting many States with low attempts per State (few per account, many accounts).

OBJECTIVE: Detect a single Source (IP) targeting many different States (accounts) with a low per-account attempt count — the hallmark of password spraying. Real Sentinel: single IP, many UPNs, low failures per UPN.

KQL QUERY (RUNNABLE ON ADX FREE TIER)

StormEvents

| where StartTime > ago(365d)

| summarize

TargetedStates = dcount(State),

StateList = make_set(State, 10),

TotalAttempts = count(),

FirstSeen = min(StartTime),

LastSeen = max(StartTime)

by Source, bin(StartTime, 10m)

| where TargetedStates > 5

and TotalAttempts < TargetedStates * 3 // low attempts per target = spray

| extend SprayRatio = round(todouble(TotalAttempts) / TargetedStates, 2)

| project

Source, TargetedStates, TotalAttempts,

SprayRatio, StateList, FirstSeen, LastSeen

| order by TargetedStates desc

| take 20

INVESTIGATION STEPS

1. Verify Source — is it a cloud hosting range or corporate IP?
2. Check if any State in StateList had a successful login after spray.
3. Determine if the IP is a Tor exit node or known VPN.
4. Review all accounts in StateList for suspicious activity.

RESPONSE ACTIONS

- Block source IP in Conditional Access Named Locations.
- Force MFA re-registration for all targeted accounts.
- Reset credentials for any account with a subsequent success.
- Notify SOC leadership if >20 accounts targeted.

Output from Above KQL Query:

```
1 StormEvents
2 | where StartTime > ago(365d)
3 | summarize
4 TargetedStates = dcount(State),
5 StateList = make_set(State, 10),
6 TotalAttempts = count(),
7 FirstSeen = min(StartTime),
8 LastSeen = max(StartTime)
9 by Source, bin(StartTime, 10m)
10 | where TargetedStates > 5
11 and TotalAttempts < TargetedStates * 3 // low attempts per target = spray
12 | extend SprayRatio = round(todouble(TotalAttempts) / TargetedStates, 2)
13 | project
14 Source, TargetedStates, TotalAttempts,
15 SprayRatio, StateList, FirstSeen, LastSeen
16 | order by TargetedStates desc
17 | take 20
```

Source	TargetedStates	TotalAttempts	SprayRatio	StateList	FirstSeen	LastSeen
No Rows To Show						

KQL Detection Query in Sentinel:

SigninLogs

| where TimeGenerated > ago(1h)

| where ResultType != "0"

| summarize

TargetedAccounts = dcount(UserPrincipalName),

AccountList = make_set(UserPrincipalName),

TotalAttempts = count(),

FirstSeen = min(TimeGenerated),

LastSeen = max(TimeGenerated)

by IPAddress, bin(TimeGenerated, 10m)

| where TargetedAccounts > 5 and TotalAttempts < TargetedAccounts * 3

| extend SprayScore = TotalAttempts / TargetedAccounts

| project

IPAddress, TargetedAccounts, TotalAttempts,

SprayScore, AccountList, FirstSeen, LastSeen

| order by TargetedAccounts desc